หลักสูตร 1 วัน · 09:00–16:30 (MFA 08:45)

Basic Security Workshop with Microsoft 365 E5



แนวคิด + สาธิต + Hands-on Workshop แบบ Guided/Scripted lab · Seed → Learn → Verify

แนวทาง: Report-only / Audit ก่อน enforcement จริง

ขอบเขต Microsoft 365 E5 + Microsoft 365 Copilot (ผู้เข้าอบรมมี license ทุกคน)

CLASS MATERIALS:
https://github.com/m3gan-lab/m365e5sec



INSTRUCTOR

คุณวรวิทย์ เสถียรพัฒนากูล (อ.อาม)

Microsoft Certified Trainer (MCT),
Certified Information Systems Security Professional (CISSP),
CompTIA Security+ & PenTest+,
Palo Alto Networks Certified Security Platform Instructor (PCSPI), &
Trend Micro Certified Trainer (TMCT)

“Bridging Complex Technology with Human-Centric Solutions”

ภาพรวมหลักสูตร

กลุ่มเป้าหมาย

- IT Administrator
- Security Administrator
- Microsoft 365 Administrator
- ทีมเทคนิค

รูปแบบ

- บรรยายแนวคิด + สาธิต + ลงมือทำ
- Lab 0 (Seed) + Lab 1–5 + Verification Checkpoint
- 7 module (M0–M6) เรียงตาม Identity → Device → Data → AI

แนวทาง

- Report-only / Audit ก่อน enforcement
- ตั้งค่า + ตรวจผลจริงเมื่อผ่านเวลา replicate
- อยู่ในขอบเขต E5 + Copilot · ส่วนที่ต้องใช้ Windows 11 ผู้สอน demo

ทุก lab: Seed ตั้งแต่เช้า → เรียนใน module → Verify เมื่อผ่านเวลา replicate (มี pre-staged example สำรอง)

กำหนดการ (1/2): ช่วงเช้า · เริ่ม 08:45 (ลงทะเบียน MFA)

09:00–09:20	**M0 · Foundations + Plan Comparison** Zero Trust, เทียบ plan และวิธีเรียน Seed → Learn → Verify
09:20–09:45	**Lab 0 · Seed Lab — Start the Clock** เริ่ม label + RCD และ demo detection test บน Windows 11 ของผู้สอน
09:45–10:55	**M1 · Defender XDR, Identity, Incident & Sign-in Analysis** Lab 1 · Sign-in risk CA, incident/alert triage, Sign-in diagnostic
10:55–11:10	พักเบรก
11:10–12:05	**M2 · Intune App Deployment, Version Control & Device Status** Lab 2 · Win32 app + Supersedence (demo บน Windows 11) และ monitor device compliance
12:05–13:05	พักกลางวัน

กำหนดการ (2/2): ช่วงบ่าย

13:05–14:00	**M3 · Sensitivity Labels & Copilot Impact** Lab 3 · Label + encryption, ถาม Copilot กับไฟล์ที่ติด label และตรวจผลใน Activity explorer
14:00–14:55	**M4 · Microsoft 365 E5 Compliance & Endpoint DLP** Lab 4 · สร้าง Endpoint DLP (Audit), demo บน Windows 11 และ DLP alert ใน Defender XDR
14:55–15:10	พักเบรก
15:10–16:00	**M5 · Copilot Governance, Agent Builder & RCD** Lab 5 · สร้าง agent เอง, agent inventory, Restricted Content Discovery
16:00–16:30	**M6 · Verification Checkpoint + Wrap-up + Q&A** ตรวจผลจริงของทุก lab แล้วทบทวน rollout checklist

ผลลัพธ์การเรียนรู้ (1/2): จบวันนี้ผู้เข้าอบรมจะสามารถ

M0	อธิบายภาพรวม E5 Security & Compliance และความต่างระหว่าง Business Premium, E3 และ E5
M1	เข้าใจ Defender XDR, Defender portal และ Entra ID Protection (Entra ID P2 ใน E5)
M1	Monitor และ triage incident/alert ใน Microsoft Defender portal
M1	วิเคราะห์ปัญหา sign-in ด้วย Entra ID Sign-in logs และ Sign-in diagnostic
M1	สร้าง Sign-in risk Conditional Access policy แบบ Report-only
M2	Deploy Win32 app ผ่าน Intune และควบคุมเวอร์ชันด้วย Supersedence

ผลลัพธ์การเรียนรู้ (2/2): จบวันนี้ผู้เข้าอบรมจะสามารถ

M2	Monitor device compliance เช่น Antivirus, Firewall และ Defender
M3	สร้างและ apply sensitivity label (manual + auto-apply) พร้อม encryption และเข้าใจ VIEW/EXTRACT กับ Copilot
M4	ออกแบบ Endpoint DLP policy และ investigate DLP alert ใน Defender XDR โดยเข้าใจ latency
M5	เข้าใจ Copilot Control System, DSPM ระดับ E5 และ Agent Builder governance
M5	สร้าง declarative agent แบบ no-code ด้วย Agent Builder ด้วยตัวเอง และดู agent ใน inventory
M5	เปิดใช้และ verify RCD บน SharePoint site พร้อมตรวจ audit event

Lab Scope Guardrails: ขอบเขตของ lab วันนี้

จุดเน้น

Microsoft 365 E5 + Microsoft 365 Copilot · ผู้เข้าอบรม 1 account ต่อคน · ส่วน Windows 11 ผู้สอน demo

Governance

Copilot Control System, Agent Builder และ DSPM ระดับ E5

ไม่ครอบคลุม

feature ของ E7 และ advanced lifecycle management / bulk action

แนวทาง

Configuration + Verification แบบ Seed → Learn → Verify มี pre-staged example สำรอง ไม่นั่งรอ latency ใน lab

MODULE 0

Foundations + Plan Comparison



เวลา 09:00–09:20

Workshop: อภิปรายและจับคู่ requirement → capability

Zero Trust **Defense-in-depth** **Business Premium vs E3 vs E5**

หลักการของ Zero Trust



Assume Breach (Assume Compromise)
Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.) and plan accordingly



Verify Explicitly
Protect assets against attacker control by explicitly validating that all trust and security decisions use all relevant available information and telemetry.

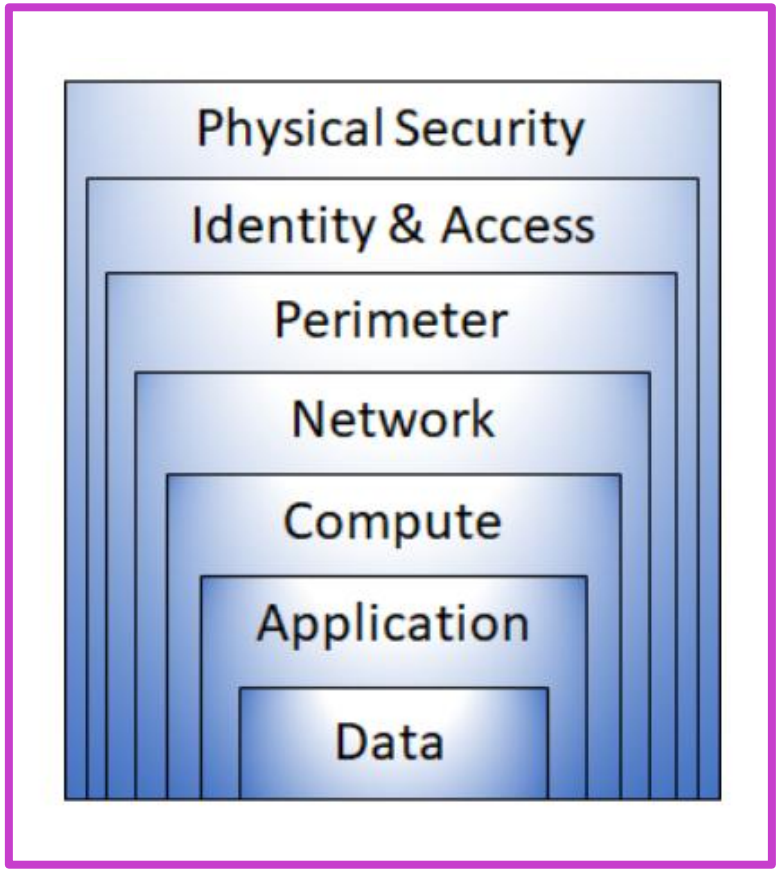


Use least privilege access
Limit access of a potentially compromised asset, typically with just-in-time and just-enough-access (JIT/JEA) and risk-based policies like adaptive access control.

Defense in depth (2/2): จาก compute ถึง data

ชั้นในสุดอยู่ใกล้ข้อมูลที่สุด จึงต้องใช้ control ที่ละเอียดที่สุด

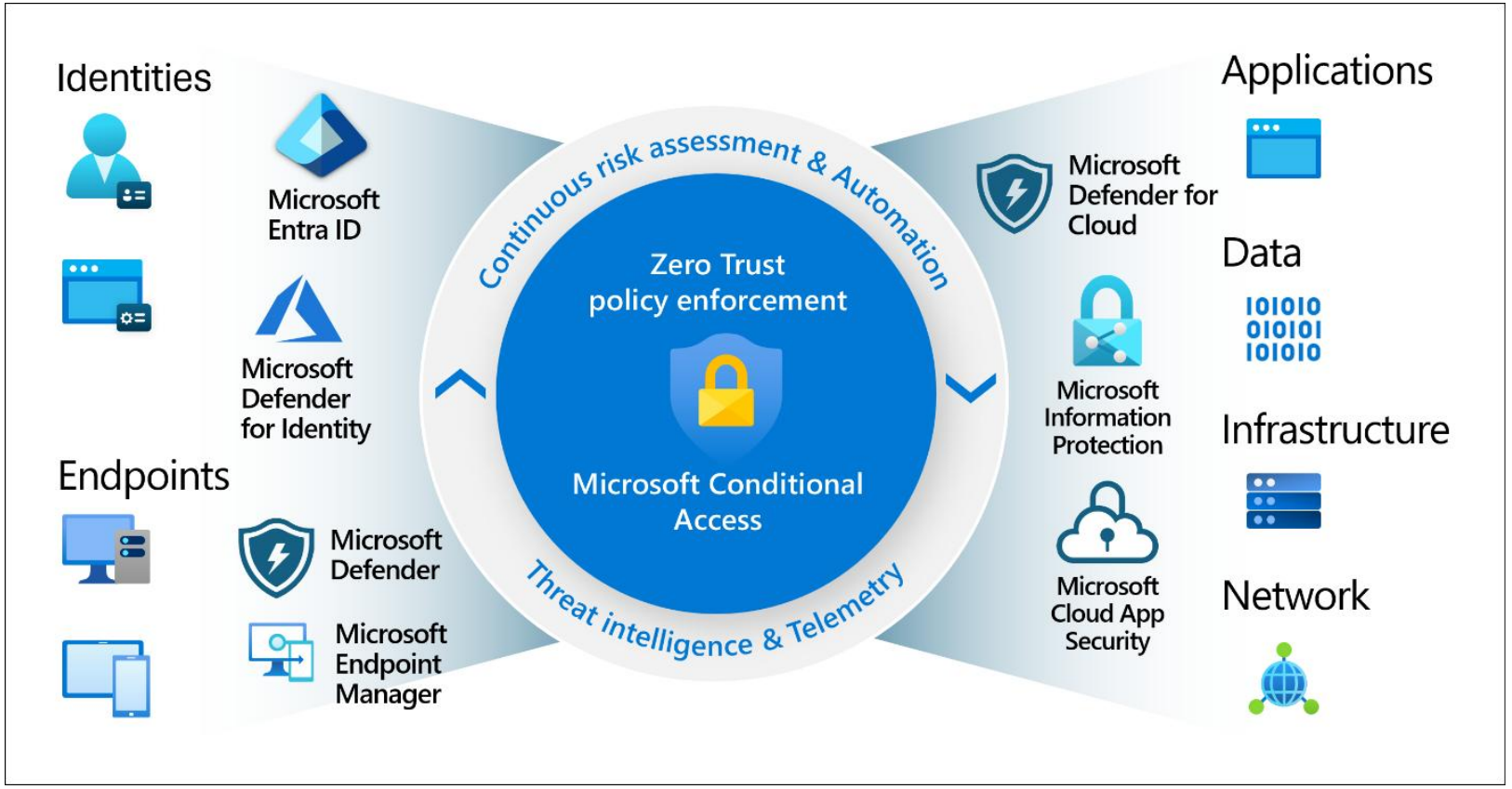
- **Compute layer security:** ปิด port ที่ไม่จำเป็น เพื่อจำกัดการเข้าถึง virtual machine
- **Application layer security:** ทำให้ application ปลอดภัยและไม่มีช่องโหว่
- **Data layer security:** ควบคุมการเข้าถึงข้อมูลธุรกิจและข้อมูลลูกค้า และใช้ encryption ปกป้องข้อมูล



ชั้นป้องกันใน workshop นี้

Identity & access: Entra ID Protection + Conditional Access (M1)
Endpoint: Defender for Endpoint + Intune (M1, M2)
Data: Purview DLP + sensitivity label (M3, M4)

Implement Zero Trust ใน Microsoft 365



Zero Trust implementation มี 6 phase:

1. ประเมิน security posture ปัจจุบัน
2. เปิดใช้ identity protection
3. บังคับใช้ endpoint compliance
4. จัดประเภทและปกป้องข้อมูล
5. Monitor และตอบสนองต่อ threat
6. ให้ความรู้ผู้ใช้ (awareness)

Defender และ identity security: BP vs E3 vs E5

E5 เพิ่ม identity risk, XDR ครบชุด และการ investigate ข้าม workload

ความสามารถ	Business Premium	Microsoft 365 E3	Microsoft 365 E5
Microsoft Entra ID	P1	P1	**P2**
Conditional Access (CA)	✓	✓	✓
Risk-based CA และ ID Protection	—	—	✓
Defender for Endpoint	Defender for Business	Plan 1	**Plan 2**
Defender for Office 365	Plan 1	Plan 1 [1]	**Plan 2**
Defender for Identity	—	—	✓
Defender for Cloud Apps	Cloud Discovery	Cloud Discovery	✓ **ครบชุด**

[1] มีผลตั้งแต่ 1 ก.ค. 2026 · BP ซื้อ Microsoft Defender Suite for Business Premium เพิ่มได้ (มี Entra ID P2, MDE P2, MDO P2)

ความสามารถของ Microsoft Purview แยกตาม plan

สิ่งที่เปลี่ยนไปเมื่อขยับจาก Business Premium หรือ E3 มาเป็น Microsoft 365 E5 โดยเน้นเฉพาะความสามารถที่ใช้ใน lab วันนี้

ความสามารถ	Business Premium	E3	E5	ใช้ใน
Sensitivity label (ติดเอง พร้อม encryption)	✓	✓	✓	Lab 3
Auto-labeling (client-side และ service-side)	—	—	✓	Lab 3
DLP สำหรับ Exchange, SharePoint, OneDrive	✓	✓	✓	M4
Endpoint DLP (device ที่เป็น Windows และ macOS)	—	—	✓	Lab 4
Activity explorer และ Content explorer	—	—	✓	Labs 2, 4
Audit	Standard	Standard	Premium	Lab 5
DSPM: ดู prompt และ response	ไม่ระบุในเอกสาร	ดูได้แค่ข้อมูล app และ activity	✓	Lab 5

สัญลักษณ์: ✓ = มีให้ใช้ — = ไม่มี
หมายเหตุ: Add-on เช่น Microsoft Purview Suite เพิ่มความสามารถระดับ E5 ได้ ควรตรวจสอบกับ Microsoft Purview service description ฉบับล่าสุดเสมอ

วิธีเรียนวันนี้: Seed → Learn → Verify

1 · Seed (Lab 0 · 09:20)

- สร้าง config ที่ต้องรอ replicate ก่อน
- ทำตามค่าใน lab guide ยังไม่ต้องเข้าใจทุก setting
- เริ่มนับเวลาตั้งแต่เช้า

2 · Learn (Lab 1–5)

- แต่ละ module อธิบายสิ่งที่ seed ไว้
- ทำ configuration ส่วนที่เหลือใน lab
- เรียง Identity → Device → Data → AI

3 · Verify (ท้าย lab + 16:00)

- ตรวจผลเมื่อผ่านเวลา replicate
- ยังไม่ขึ้น → ใช้ pre-staged example
- Verification Checkpoint ตรวจครบทุกรายการ

ทำไมต้องรอ

Label policy สูงสุด 24 ชม. (ปกติ ~2 ชม.) · Endpoint DLP policy ~1 ชม. · Audit / Activity explorer 60–90 นาที · Auto-labeling simulation ~12 ชม. ตาม Learn (ซ้อมครั้งหนึ่ง 52 วินาที)

Shared lab tenant: กติกาของห้องนี้

Prefix ของตัวเอง

ตั้งชื่อทุก object ด้วยเลขประจำตัว เช่น S01-Confidential, S01-EDLP, S01-Agent

Scope เฉพาะของตัวเอง

Assign ให้ Sxx-lab, Sxx-Devices หรือ Sxx-Site เท่านั้น ห้ามเลือก All users / All devices

Tenant-wide setting: ดูอย่างเดียว

Endpoint DLP settings, Alert tuning, Alert service settings และ Auditing ผู้สอนตั้งไว้ก่อนคลาส · DEMO-PC และ object ที่ขึ้นต้นด้วย DEMO ดูอย่างเดียว

Lab kit ของแต่ละคน

Sxx-lab (account เดียว) · Sxx-Devices (กลุ่มว่าง) · Sxx-Site (มี sample files แล้ว) · App-v1/v2.intunewin

วันนี้ใครทำอะไร: ผู้เข้าอบรมลงมือเอง vs ผู้สอน demo

Lab	ผู้เข้าอบรมลงมือเอง (account Sxx-lab)	ผู้สอน demo (Windows 11 VM · อีกสอง identity)
Lab 0	label + label policy · เปิด RCD บน Sxx-Site	พาดู DEMO-PC แล้วรัน detection test
Lab 1	CA แบบ Report-only บน account ตัวเอง · Sign-in logs · What If · ดู incident (ดูอย่างเดียว)	Manage alert / triage บน incident ของ DEMO-PC
Lab 2	เพิ่ม Win32 app v1/v2 + Supersedence ใน Intune · ดู compliance policy	Package .intunewin · deploy, Sync และดูผลบน DEMO-PC
Lab 3	ดู label + encryption · ติด label แล้วถาม Copilot กับไฟล์นั้น · Activity explorer	Copilot กับไฟล์ที่ encrypt (DEMO-userA Editor เทียบ DEMO-userB Viewer)
Lab 4	สร้าง Endpoint DLP policy (Audit only) · ดู DLP settings	ทดสอบ upload / unallowed browser บน DEMO-PC · ดู DLP alert
Lab 5	สร้าง agent เอง · ดู agent inventory · ตรวจ tag Restricted และ audit event ของ RCD	Block/Unblock DEMO-Agent-2 · เทียบผล RCD ด้วย DEMO-userA

LAB 0

Seed Lab — Start the Clock



เวลา 09:20–09:45
สร้าง config ที่ต้องรอ replicate แล้วกลับมาตรวจภาคบ่าย

Label + policy **RCD** **Auto-label (เสริม)** **Demo: Windows 11**

Lab 0 at a glance: งานของเรา 2 งาน + demo ผู้สอน

#	งาน seed	พร้อมหลัง (โดยทั่วไป)	ตรวจใน
0.1	sample files ใน Sxx-Site (ผู้สอน upload ไว้ให้แล้ว ไม่ต้องทำ)	พร้อมแล้ว	Lab 3
0.2	Sensitivity label + label policy	ปกติ ~2 ชม. · ทุก app สูงสุด 24 ชม.	Lab 3
0.3	(งานเสริม) Auto-labeling policy (simulation)	~12 ชม. ตาม Learn (ซ้อม 52 วินาที)	Lab 3
0.4	เปิด RCD บน Sxx-Site (ห้ามเปิดไฟล์ PublicAnnouncement.docx)	tag เร็ว · ผลต่อ Copilot นานกว่านั้น · audit 60–90 นาที	Lab 5
Demo	**DEMO** · ผู้สอนพาดู DEMO-PC (Windows 11) แล้วรัน detection test	~10 นาที	Lab 1

Lab 0 ขั้นตอน (1/2): Microsoft Purview

#	ที่ไหน	ค่าที่ใช้
0.1	Sxx-Site > Documents	ผู้สอน upload sample files (มี test credit card number) ไว้แล้ว: ไม่ต้องทำ ผู้สอนจะบอกว่าไฟล์อยู่ที่ไหน (อย่าเปิด PublicAnnouncement.docx)
0.2	Information Protection > Sensitivity labels	Sxx-Confidential · Files & other data assets · Assign permissions now Sxx-lab = Editor · DEMO-userB = Viewer · ไม่มีวันหมดอายุ Publish ด้วย Sxx-LabelPolicy ให้ Sxx-lab (ไม่ตั้ง default label)
0.3	Information Protection > Auto-labeling policies	(งานเสริม ทำเมื่องานหลักเสร็จ) Sxx-AutoLabel · label Sxx-Confidential · location Sxx-Site SIT Credit Card Number · Run in simulation · ไม่ติ๊ก automatic turn-on

Lab 0 ขั้นตอน (2/2): SharePoint และ demo บน Windows 11

#	ที่ไหน	ค่าที่ใช้
0.4	SharePoint admin center > Active sites > Sxx-Site > Settings	เปิด Restrict content discovery = On แล้วกด Save (ห้ามเปิดไฟล์ PublicAnnouncement.docx)
Demo	DEMO-PC: Command Prompt (Run as administrator)	**DEMO** · ผู้สอนสร้าง C:\test-MDATP-test แล้วรันคำสั่ง detection test จาก lab kit บน Windows 11 (หน้าต่างจะปิดเอง) ผู้เข้าอบรมดูบนจอ
!	ถ้าเวลาไม่พอ	ทำงานหลักตามลำดับ 0.2 → 0.4 แล้วค่อยทำงานเสริม 0.3 ถ้ายังมีเวลา

MODULE 1

Defender XDR, Identity, Incident Monitoring & Sign-in Analysis



เวลา 09:45–10:55

Lab 1 · Sign-in risk CA (Report-only), incident triage, Sign-in diagnostic

Defender XDR **Entra ID Protection** **Conditional Access** **Sign-in logs**

Antivirus, EDR และ XDR ต่างกันอย่างไร

จากยามหน้าประตู → กล้องวงจรปิดพร้อมทีมสืบสวน → ศูนย์ควบคุมรวมทั้งตึก



Antivirus (AV)

เหมือนยามหน้าประตู

ตรวจไฟล์และโปรแกรมบนเครื่องว่าตรงกับ malware ที่รู้จัก หรือมีพฤติกรรมน่าสงสัยไหม ถ้าใช่ก็ block หรือลบทันที

ตอบว่า: ไฟล์นี้อันตรายไหม



EDR

เหมือนกล้องวงจรปิด + ทีมสืบสวน

บันทึกสิ่งที่เกิดบนเครื่องต่อเนื่อง เช่น โปรแกรมที่ถูกเปิดและการเชื่อมต่อเครือข่าย ย้อนดูได้ภายหลัง และสั่งตอบโต้ได้ เช่น isolate device

ตอบว่า: เกิดอะไรขึ้นบนเครื่องนี้ ลามไปไหนหรือยัง



XDR

เหมือนศูนย์ควบคุมรวมทั้งตึก

รวมสัญญาณจาก device, email, identity และ cloud app มาต่อเป็นเรื่องเดียว (incident) แล้วตอบโต้ข้ามระบบได้ในที่เดียว

ตอบว่า: การโจมตีเริ่มจากไหน กระทบใครบ้าง

ไม่ได้แทนกัน แต่ต่อยอดกัน

- Defender Antivirus เป็นส่วนหนึ่งของ Defender for Endpoint · EDR ในตัวเดียวกันเก็บบันทึกกิจกรรมของเครื่องไว้ให้สืบสวน
- Microsoft Defender XDR รวม signal จาก Endpoint, Office 365, Identity และ Cloud Apps เข้ามาในหน้า Incidents เดียวกัน

ตัวอย่าง: phishing email ฉบับเดียว แต่ละระบบเห็นอะไร

สมมติว่า (เหตุการณ์สมมติ ใช้อธิบายเท่านั้น) พนักงานคนหนึ่งได้รับอีเมลหลอกลวงหนึ่งฉบับ

สิ่งที่เกิดขึ้น	1. อีเมลหลอกส่งถึงกล่องจดหมาย	2. ผู้ใช้คลิกลิงก์และกรอกรหัสผ่าน	3. คนร้าย sign-in ด้วยรหัสนั้นจากที่อื่น	4. มัลแวร์ถูกรันบนเครื่อง
Antivirus	ไม่เห็น	ไม่เห็น	ไม่เห็น	เห็นเฉพาะไฟล์ที่รันบนเครื่อง
EDR	ไม่เห็น	ไม่เห็น	ไม่เห็น	เห็นละเอียด ย้อนดูได้ และสั่ง isolate ได้
XDR	**เห็นครบทั้ง 4 ขั้น และต่อเป็น incident เดียว** รู้ว่าเริ่มจากอีเมลฉบับไหน ใครคลิก บัญชีไหนถูกใช้ และเครื่องไหนโดน			

XDR เห็นได้เฉพาะ signal จาก product ที่มี license และเปิดใช้แล้ว (อีเมล = Defender for Office 365, sign-in = Entra ID Protection, เครื่อง = Defender for Endpoint)

Defender XDR signals: แต่ละ source ส่งอะไรเข้ามา

ทุก source ในตารางมีใน Microsoft 365 E5 · แถวสีม่วงคือ source ที่ใช้ใน lab วันนี้

Signal source	ส่ง signal อะไรเข้า Defender XDR	ใช้ในคลาส
Microsoft Defender for Endpoint	Process, file, network event และ alert จาก device	M1 triage · M2
Microsoft Defender for Office 365	Phishing email, malicious URL และ attachment	M1 ภาพรวม
Microsoft Defender for Identity	การโจมตี identity บน on-premises Active Directory เช่น lateral movement	M1 ภาพรวม
Microsoft Defender for Cloud Apps	Activity ผิดปกติใน SaaS app และ OAuth app	M1 ภาพรวม
Microsoft Entra ID Protection	Sign-in risk และ user risk	M1 · Lab 1
Microsoft Purview DLP	DLP policy match จาก device, email และไฟล์	M4 · Lab 4

Defender for Identity ต้องติดตั้ง sensor บน domain controller ก่อน จึงจะมี signal เข้ามา

Defender for Endpoint: Business vs Plan 1 vs Plan 2

Plan 1 = ป้องกันพื้นฐาน · Plan 2 = เพิ่ม detection และ investigation · Business = แพ็กสำหรับ SMB

ความสามารถ	Defender for Business	Plan 1	Plan 2
Antivirus และ attack surface reduction	✓	✓	✓
EDR (detection และ investigation บน device)	✓ แบบปรับให้ง่าย	—	✓
Automated Investigation and Remediation (AIR)	✓	—	✓
Vulnerability management (core)	✓	—	✓
เก็บข้อมูล 6 เดือน + Microsoft Defender Experts	—	—	✓
ตั้งค่า firewall และ antivirus แบบง่าย (Windows)	✓	—	—
มีใน license	Business Premium	Microsoft 365 E3	**Microsoft 365 E5**

Defender for Business ออกแบบให้องค์กรไม่เกิน 300 users · Plan 1 สั่ง manual response action ได้ เช่น quarantine ไฟล์ · Windows/Linux server ต้องมี license เพิ่ม

Defender for Office 365: Plan 1 vs Plan 2

Plan 1 ป้องกัน email threat · Plan 2 เพิ่มสืบสวน ตอบสนองอัตโนมัติ และ phishing simulation

ความสามารถ	Plan 1	Plan 2
Safe Links, Safe Attachments และ anti-phishing	✓	✓
เครื่องมือ investigate email threat	Real-time detections	**Threat Explorer (Explorer)**
Threat Trackers และ Campaign views	—	✓
Automated Investigation and Response (AIR)	—	✓
Attack simulation training	—	✓
Advanced hunting และ incident ใน Defender XDR	—	✓
มีใน license	Business Premium, Microsoft 365 E3 [1]	**Microsoft 365 E5**

[1] E3 ได้ตั้งแต่ 1 ก.ค. 2026 · เช็กใน Defender portal: Email & collaboration > Explorer = Plan 2, Email & collaboration > Real-time detections = Plan 1

Defender for Cloud Apps: Cloud Discovery vs ครบชุด

Cloud Discovery ช่วยให้เห็น · แบบครบชุดช่วยให้ควบคุมและตรวจจับภัยด้วย

ความสามารถ	Cloud Discovery	ครบชุด
ขอบเขต	ด้านเดียว: cloud discovery (ส่วนย่อย)	**4 ด้าน: CASB, SSPM, threat protection, app-to-app**
ค้นหา cloud app ที่ใช้ (Shadow IT) และประเมินความเสี่ยง	✓	✓
Anomaly detection ของ app ที่ค้นพบ	—	✓
DLP ข้าม SaaS app และควบคุมการแชร์ข้อมูล	—	✓
ดูและเพิกถอนสิทธิ์ OAuth app (app governance)	—	✓
ตรวจจับภัยใน SaaS app และส่ง alert เข้า Defender XDR	—	✓
มีใน license	Entra ID P1, M365 E3 (ไม่คิดเพิ่ม)	**Microsoft 365 E5 หรือซื้อแยก**

Conditional Access App Control ต้องมี Entra ID P1 ร่วมด้วย · Business Premium มี Entra ID P1 จึงได้ Cloud Discovery ตามตาราง BP vs E3 vs E5 ก่อนหน้า

Microsoft Entra ID: P1 vs P2

P2 คือ P1 บวก Identity Protection และ PIM

ความสามารถ	Entra ID P1	Entra ID P2
Conditional Access และ MFA	✓	✓
Dynamic groups และ self-service group management	✓	✓
Hybrid identity: Application Proxy, password writeback	✓	✓
Identity Protection: risk-based Conditional Access (CA)	—	✓
Privileged Identity Management (PIM): สิทธิ์ admin แบบ just-in-time (JIT)	—	✓
Entitlement management และ access reviews	—	✓ [1]
มีใน license	Business Premium, Microsoft 365 E3	**Microsoft 365 E5**

[1] ความสามารถพื้นฐานที่เคยอยู่ใน P2 ส่วนที่ใหม่กว่าต้องใช้ Microsoft Entra ID Governance เพิ่ม · Lab 1 ใช้ Identity Protection ซึ่งต้องมี P2

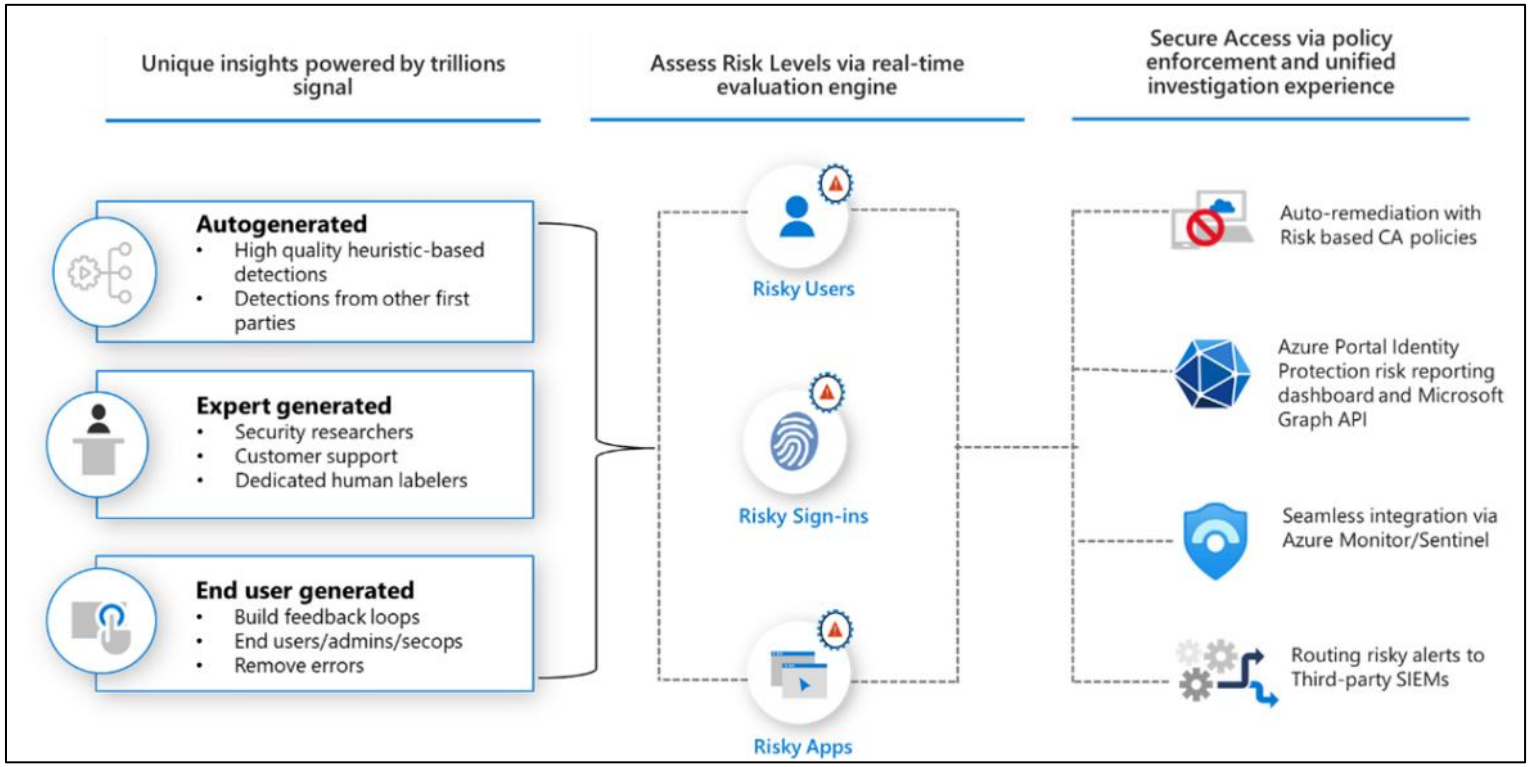
Entra ID Protection (1/2): Detect และ Investigate

Detect

- User risk
- Sign-in risk

Investigate

- Risk detections report
- Risky sign-ins report
- Risky users report
- Risky workload identities report



License ที่ต้องใช้กับ Identity Protection

ความสามารถ		Microsoft Entra ID Free/ Microsoft 365 Apps	Microsoft Entra ID Premium P1	Microsoft Entra ID Premium P2
User risk policy (CA)		ไม่มี	ไม่มี	มี
Sign-in risk policy (CA)		ไม่มี	ไม่มี	มี
Security report	Overview	ไม่มี	ไม่มี	มี
	Risky users	ข้อมูลจำกัด *	ข้อมูลจำกัด *	เข้าถึงได้เต็มที่
	Risky sign-ins	ข้อมูลจำกัด *	ข้อมูลจำกัด *	เข้าถึงได้เต็มที่
	Risk detection	ไม่มี	ข้อมูลจำกัด *	เข้าถึงได้เต็มที่
การแจ้งเตือน	User at risk alert	ไม่มี	ไม่มี	มี
	Weekly digest	ไม่มี	ไม่มี	มี
MFA registration policy		ไม่มี	ไม่มี	มี

* ดูรายละเอียด license เพิ่มเติมได้ที่ Microsoft Learn:
https://learn.microsoft.com/en-us/entra/id-protection/overview-identity-protection

Conditional Access: policy คือ if-then

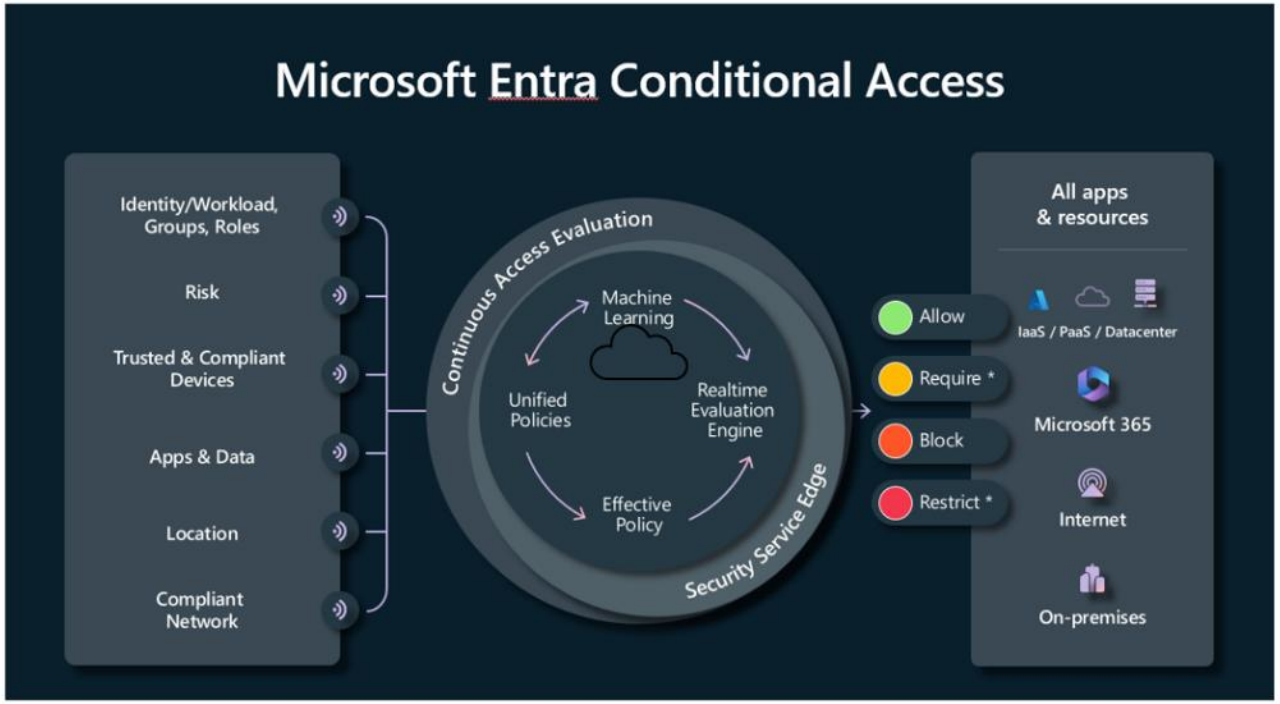
ถ้าตรงเงื่อนไข (assignments) ก็บังคับใช้ access control ที่กำหนด

Assignments: ใช้ signal อะไรตัดสินใจ

- Users, groups, workload identities, directory roles
- Cloud apps หรือ actions (All resources = ทุกแอป)
- Sign-in risk และ user risk
- Device, device platform และ IP location

Access controls: บังคับใช้อย่างไร

- Block access
- Grant access: ต้องผ่านก่อน เช่น MFA (authentication strength = ชุดวิธีที่ยอมรับ)
- Session control: จำกัด experience
- State: Report-only = จำลอง, On = บังคับ



Report-only: อ่านผลก่อนเปิดบังคับใช้

Policy ถูก evaluate ทุก sign-in แต่ไม่บังคับ control ใดๆ ผลจะถูกบันทึกใน sign-in log

Report-only: Success
เงื่อนไขครบ และ control ที่ user ไม่ต้องโต้ตอบผ่าน เช่น token มี MFA claim อยู่แล้ว

Report-only: Failure
เงื่อนไขครบ แต่ control ไม่ผ่าน เช่น policy แบบ Block ถ้าเปิด On จะถูก block

Report-only: User action required
ต้องให้ user ทำเพิ่ม เช่น MFA แต่ report-only ไม่ prompt จึงยังสรุปผลไม่ได้

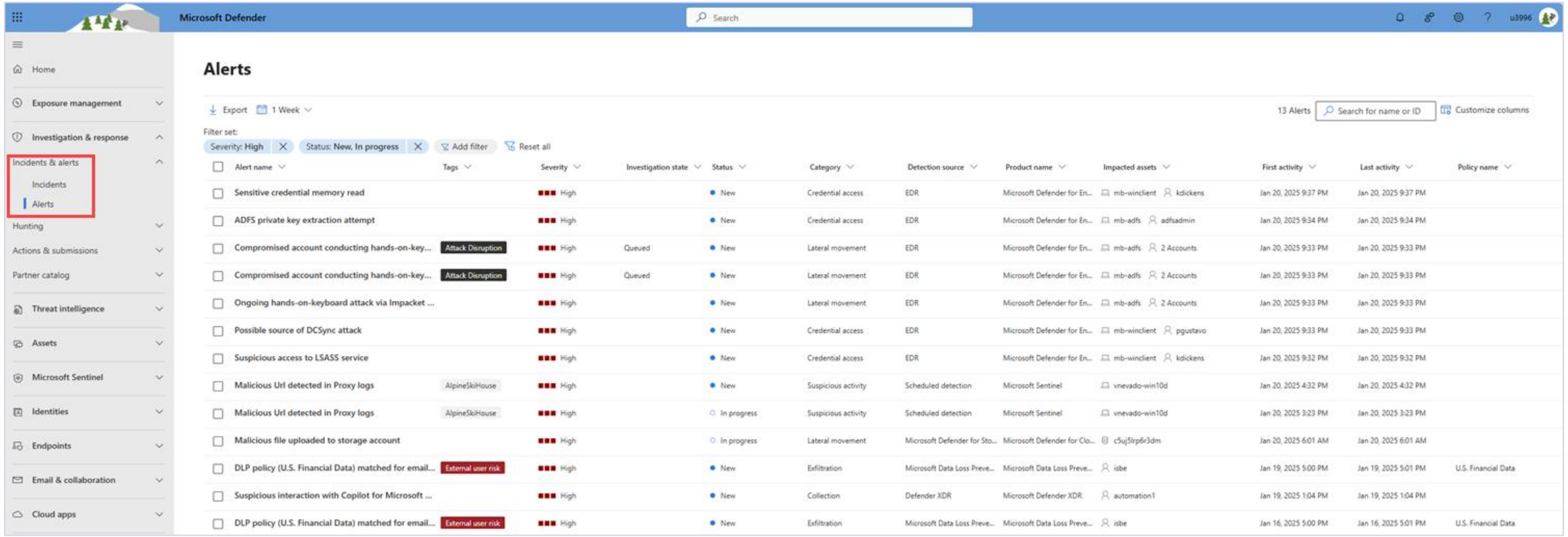
Report-only: Not applied
เงื่อนไขไม่ครบ เช่น user ถูก exclude หรือ sign-in risk ไม่ถึงระดับที่ตั้งไว้

ดูผลได้ที่ไหน

1. Sign-in logs > User sign-ins (interactive) > เลือก event > tab Report-only
2. Conditional Access > Insights and reporting (ต้องใช้ Log Analytics workspace)
3. Download sign-in log เป็น JSON เพื่อให้มีผล report-only

Alerts queue: ดู alert ทีละรายการ

Incidents & alerts > Alerts — ใช้เมื่อต้องการดูหลักฐานแต่ละชิ้นละเอียดกว่าระดับ incident



ภาพจาก Microsoft Learn: Investigate alerts in Microsoft Defender XDR · ข้อมูลตัวอย่างของ Microsoft ไม่ใช่ข้อมูลใน tenant ของ lab

Alert
หลักฐานหนึ่งชิ้นจาก source เดียว

Incident
หลาย alert ที่ correlate เป็น attack story เดียว

- **ค่าเริ่มต้น:** alert ที่ New และ In progress ของ 7 วันล่าสุด
- **Filter / Search:** Severity, Status, Service/detection sources, Entities · ค้นหาด้วยชื่อหรือ ID
- **Source ใน lab:** Microsoft Entra ID Protection (Lab 1), Microsoft Data Loss Prevention (Lab 4)

AIR: ระบบสืบสวนและแก้ไขเบื้องต้นให้อัตโนมัติ

Automated Investigation and Response — ทำต่อจาก alert ของ EDR แทนขั้นตอนที่นักวิเคราะห์ทำซ้ำๆ

1 · Alert เกิดขึ้น

เช่น เจอไฟล์อันตรายบนเครื่อง หรืออีเมลน่าสงสัย ระบบเริ่มสืบสวนเอง

2 · ระบบสืบสวน

ไล่ตรวจหลักฐานทีละชิ้น ให้ verdict (คำตัดสิน): Malicious, Suspicious หรือ No threats found

3 · แก้ไข

เช่น quarantine ไฟล์ ทำเองหรือรอคนอนุมัติ ดูย้อนหลังและ Undo ได้ที่ Action center

สถานะปัจจุบัน (ตรวจเมื่อ 5 พ.ย. 2026) ต่างกันตามผลิตภัณฑ์

Defender for Endpoint (เครื่อง)

- ตั้งแต่ 1 ก.ย. 2026 AIR ไม่เป็นหน้า Investigation แยก และสั่งเริ่ม Investigation เองไม่ได้แล้ว
- ความสามารถนี้ฝังอยู่ใน Defender Antivirus และทำงานอัตโนมัติ
- ถ้าต้องการตรวจเอง ให้รัน full antivirus scan
- AIR ต้องมี Defender Antivirus เปิดอยู่ (active หรือ passive)

Defender for Office 365 Plan 2 (อีเมล, ใน E5)

- AIR ยังใช้ได้เหมือนเดิม
- สืบสวนอีเมลน่าสงสัย แล้วเสนอ action เช่น ลบอีเมล
- SecOps อนุมัติหรือปฏิเสธที่ Action center
- ดูรายการสืบสวนได้ที่ Investigations ใน Defender portal

Lab 1 walkthrough: practice (Defender XDR และ Identity)

#	ทำใน lab	Key Topic
1	สร้าง Sxx-CA-SigninRisk ให้ Sxx-lab (account ตัวเอง) · Sign-in risk ≥ Medium · MFA · Report-only	Conditional Access + sign-in risk: condition นี้มาจาก Entra ID Protection (P2) · Report-only จึงไม่กระทบใคร ห้ามเปลี่ยนเป็น On
2	Sign-in ซ้ำด้วย Sxx-lab ใน InPrivate แล้วเปิด Sign-in logs > tab Report-only	Entra ID Sign-in logs: อ่าน Success / Failure / User action required (ไม่มี risk = Not applied) · เลือกแถว Success · Show details = ดูข้อที่ Not matched
3	What If กับ user, app และ risk level	What If = จำลองผลโดยไม่ต้อง sign-in จริง · ช่อง risk ว่าง = none จึงได้ Not applied · ทดสอบ policy ก่อน enforce
4	**DEMO** · รัน detection test บน DEMO-PC (Windows 11) · alert ขึ้นใน ~10 นาที	Detection test เป็นคำสั่งจาก Microsoft Learn · เครื่องส่ง signal เข้า Defender for Endpoint
5	Defender: Investigation & response > Incidents & alerts: เปิด incident ของ DEMO-PC แล้วไล่ severity, assets, entities, timeline (ดูอย่างเดียว)	Incidents queue vs alerts queue, filter Service source · Manage alert (status, assign, classification) ผู้สอน demo
6	เปิด Settings > Microsoft Defender XDR > Alert service settings (ดูอย่างเดียว)	Entra ID Protection alert service setting: ผู้สอนตั้งไว้ High + Medium (default ของ Learn = High only) · ตั้งต่ำ = alert เยอะ, ตั้งสูง = อาจพลาด
7	Troubleshoot event Failure ตัวอย่างของผู้สอน (ตั้ง Date range = Last 7 days ถ้าไม่เห็นแถว)	Troubleshoot with Self-Service Support / Launch the Sign-in Diagnostic + Correlation ID · ไม่ต้องใส่รหัสผ่านผิดเอง

Module 2 · Intune app deployment และ device compliance

11:10–12:05 · concept + demo + Lab 2

1. **Win32 app deployment**
   Package, rule, assignment
2. **Version control ด้วย Supersedence**
   Update vs replace · expected behavior
3. **Monitor app deployment**
   Install status · IME log
4. **Device compliance**
   Firewall · Antivirus · Defender

จบ module นี้แล้วทำได้

- Deploy Win32 app ด้วย Intune
- อธิบาย configuration และ expected behavior ของ Supersedence
- Monitor device compliance — Antivirus, Firewall, Defender

สร้างไฟล์ .intunewin ด้วย IntuneWinAppUtil.exe

ก่อน package ต้องมีอะไร

- IntuneWinAppUtil.exe (Win32 Content Prep Tool) รันได้บน Windows เท่านั้น
- โฟลเดอร์ source: ใส่ไฟล์ติดตั้งเพียง 1 ไฟล์ (lab นี้คือ MSI ของ 7-Zip)
- โฟลเดอร์ output: ปล่อยว่างไว้ ผลลัพธ์จะออกที่นี่

.intunewin คืออะไร

- ไฟล์ติดตั้งที่แปลงให้ Intune รับได้ ใช้ตอน Select app package file
- MSI: เครื่องมือดึง product code ให้
- ใน lab เปลี่ยนชื่อเป็น App-v1 / App-v2

- **ดาวน์โหลดเครื่องมือ**: **github.com/microsoft/Microsoft-Win32-Content-Prep-Tool** (ไฟล์ IntuneWinAppUtil.exe, v1.8.7) · ต้องมี .NET Framework 4.7.2
- **คำสั่ง**: `IntuneWinAppUtil.exe -c <source_folder> -s <setup_file> -o <output_folder> -q`
- -c = โฟลเดอร์ต้นทาง · -s = ไฟล์ติดตั้ง · -o = โฟลเดอร์ผลลัพธ์ · -q = ไม่ถามเพิ่ม
- รันใน Command Prompt (ไม่ต้อง Run as administrator) บน DEMO-PC · ผู้เข้าอบรมไม่ต้อง package เอง รับ App-v1/v2.intunewin จาก lab kit

Supersedence — update หรือ replace Win32 app

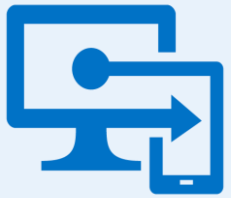
Update — app เดิม เวอร์ชันใหม่

- Uninstall previous version = **No**
- Installer ของเวอร์ชันใหม่อัปเกรดทับของเดิม

Replace — เปลี่ยนเป็น app อื่น

- Uninstall previous version = **Yes**
- Intune uninstall app เดิมก่อน แล้วจึงติดตั้ง app ใหม่

- Superseding app ต้องมี assignment ของตัวเอง — ไม่มี automatic targeting
- หนึ่ง supersedence relationship มีได้สูงสุด 10 app
- Auto-update ใช้ได้เฉพาะ **Available for enrolled devices** ที่เปิด Auto-update — ปกติใช้เวลา 8–16 ชั่วโมง



Supersedence — ผลที่คาดหวังบน device

A = app เดิม (superseded) · B = app ใหม่ (superseding) · ทั้งคู่ถูก target และ applicable

บนเครื่องมีอยู่แล้ว	Update (Uninstall previous version = No)	Replace (Uninstall previous version = Yes)
ไม่มีทั้งคู่	ติดตั้ง B	ติดตั้ง B
มีแค่ A	ติดตั้ง B — A หายเฉพาะเมื่อ installer ของ B ถอนให้	Uninstall A แล้วติดตั้ง B
มีแค่ B	ไม่ทำอะไร	ไม่ทำอะไร
มีทั้ง A และ B	ไม่ทำอะไร — A ยังอยู่	Uninstall A

Replace: Intune จะถอน A ก่อน แล้วจึงติดตั้ง B แต่ถ้าถอนแล้วยังตรวจเจอ A อยู่ Intune จะไม่ติดตั้ง B

วิธีแก้: ตรวจ detection rule ของ A (กฎที่ Intune ใช้เช็กว่า A ติดตั้งอยู่หรือไม่) ว่าตั้งค่าถูกต้อง

Windows compliance policy ตรวจอะไรได้บ้าง

Windows 10 and later · ตัวหนา = setting ที่ใช้ใน Lab 2

Category	Settings
Device Health	Require BitLocker · Require Secure Boot to be enabled on the device · Require code integrity
System Security	**Firewall** · Trusted Platform Module (TPM) · **Antivirus** · Antispyware
Defender	**Microsoft Defender Antimalware** · Microsoft Defender Antimalware minimum version · Microsoft Defender Antimalware security intelligence up-to-date · **Real-time protection**
Microsoft Defender for Endpoint	Require the device to be at or under the machine risk score

Platform อื่น (ไม่อยู่ใน lab วันนี้): iOS/iPadOS · Android Enterprise · macOS — ตรวจ jailbreak/root, encryption, OS version

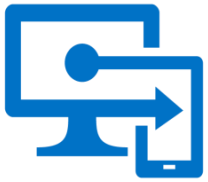
Compliance และ Conditional Access — ห่วงโซ่ Zero Trust

Intune ประเมิน · Microsoft Entra Conditional Access บังคับใช้



Defender

ผู้ใช้คลิก phishing link — device risk ขึ้นเป็น High



Intune

ประเมิน compliance — ตั้งเครื่องเป็น Not compliant



Conditional Access

เห็นสถานะ Not compliant — block Teams และ Microsoft 365



Remediation

แจ้งผู้ใช้ — สั่ง AV scan เพื่อเคลียร์

- สถานะเครื่องไหลจาก Defender → Intune → Conditional Access อัตโนมัติ เมื่อแก้ไขแล้วสิทธิ์เข้าถึงจะกลับมา
- เงื่อนไข: เปิด machine risk score ใน compliance policy และเริ่ม Conditional Access แบบ **Report-only** ก่อนเปลี่ยนเป็น **On**

เรื่องเวลา — สิ่งที่ไม่ต้องรอใน lab

เหตุการณ์	ระยะเวลาโดยทั่วไป	ใน lab ทำอย่างไร
IME check-in (Win32 app)	ทุก 8 ชั่วโมง	ผู้สอนกด Company Portal > Settings > Sync บน DEMO-PC
Supersedence auto-update (Available)	8–16 ชั่วโมง (2 รอบ check-in)	อธิบาย expected behavior — ไม่ต้องรอ
Compliance status ใน report	สูงสุด 24 ชั่วโมง	ดูสถานะของ DEMO-PC ที่ report ไว้ก่อนคลาส
Required app ถูกถอนออก	ติดตั้งใหม่ภายใน ~24 ชั่วโมง	อธิบายอย่างเดียว
Firewall / Antivirus / Defender เปลี่ยนค่า	ประเมินใหม่เร็วกว่า (real-time monitoring)	เหมาะกับ demo สด

Lab 2 walkthrough: practice (Intune)

#	ทำใน lab	Key Topic
1	เพิ่ม Sxx-App v1 จาก App-v1.intunewin: Program, Requirements, Detection rules · assign Required ให้ Sxx-Devices	Win32 app deployment: install/uninstall command, requirement rule, detection rule · Sxx-Devices เป็นกลุ่มว่าง จึงไม่มีการติดตั้งจริง
2	**DEMO** · Package v2 ด้วย IntuneWinAppUtil.exe บน DEMO-PC (Windows 11)	.intunewin และสิ่งที่ต้องเตรียมก่อน package · ผู้เข้าอบรมรับไฟล์ App-v2.intunewin จาก lab kit
3	Add Sxx-App v2 จาก App-v2.intunewin แล้ว assign ให้ Sxx-Devices	Assignment: Required vs Available · superseding app ต้อง assign เอง
4	ตั้ง Supersedence ที่ v2 ให้แทน v1: เทียบ Update กับ Replace	Uninstall previous version = No / Yes · auto-update 8–16 ชม. (Available เท่านั้น) · เลือก Sxx-App v1 ของเรา ห้ามเลือก DEMO-App v1
5	**DEMO** · DEMO-PC: ดู DEMO-App v1 ที่ติดตั้งแล้ว → เพิ่ม v2 + Supersedence → Company Portal > Sync	Monitoring: Installed / Failed / Install pending · IME log · เห็นผล Update/Replace จริงบนเครื่อง
6	Devices > DEMO-PC > Device compliance และเปิด compliance policy ที่ผู้สอน assign ไว้ (ดูอย่างเดียว)	Device compliance: Firewall, Antivirus, Defender · ผลนี้ส่งต่อให้ Conditional Access

MODULE 3

Sensitivity Labels & Copilot Impact



เวลา 13:05–14:00

Lab 3 · Label + encryption และ Activity explorer

Sensitivity labels | Auto-apply | VIEW / EXTRACT | Activity explorer

ภาพรวม Sensitivity label

Microsoft Purview Information Protection ใช้ sensitivity label เพื่อจัดประเภทและปกป้องข้อมูลทั่วทั้ง Microsoft 365 โดย label ให้การปกป้องที่สม่ำเสมอ และยังทำงานได้อย่างปลอดภัยและมีประสิทธิภาพ

ปกป้องเนื้อหา



- Encrypt ไฟล์และอีเมล
- ใส่ visual marking เช่น header, footer และ watermark

ใช้และบังคับ control



- จำกัด action บนไฟล์ อีเมล และ chat
- บังคับการปกป้อง ข้าม device, app และ cloud service
- ปกป้อง container เช่น Teams, SharePoint site และ Microsoft 365 Groups

จัดระเบียบและขยายการใช้ label



- ใช้ label group จัดกลุ่ม label ที่เกี่ยวข้องกัน
- เชื่อมการ labeling เข้ากับ Microsoft 365 Copilot เพื่อปกป้องเนื้อหาที่ AI สร้าง
- ตั้ง Priority เลขมาก = ลับกว่า ชนะเมื่อขัดแย้ง

ตั้งค่า encryption ด้วย sensitivity label

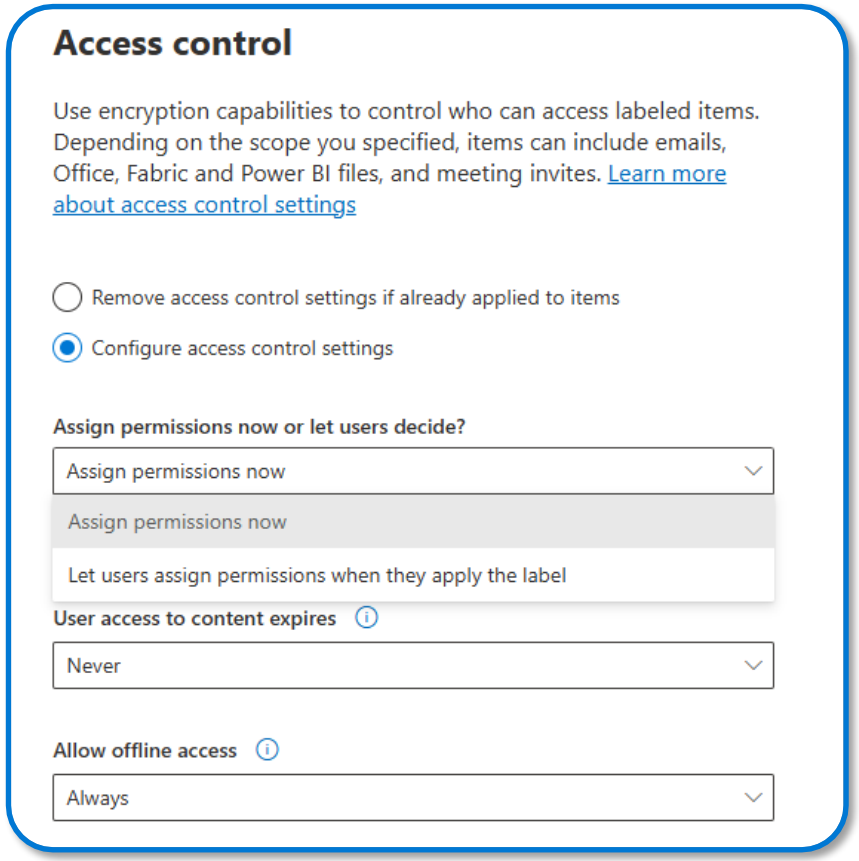
Sensitivity label ใน Microsoft Purview ใช้ encryption ปกป้องเนื้อหา ไม่ว่าจะจัดเก็บหรือแชร์ไว้ที่ใด

Access control

- Assign permissions now: admin เป็นผู้กำหนด access control
- Let users assign permissions: user เลือกเองว่าใครได้ permission ใดตอนติด label

การทำงานของ encryption

- Persistent protection: encryption ติดไปกับไฟล์หรืออีเมลเสมอ
- Policy-based rule: setting เดียวกันกับทุกเนื้อหาที่ติด label
- Expiration และ offline access: ควบคุมว่าเนื้อหาเปิดได้นานแค่ไหน
- Azure Rights Management (Azure RMS): ใช้ encryption ที่อิงกับ identity



Implement auto-labeling policy

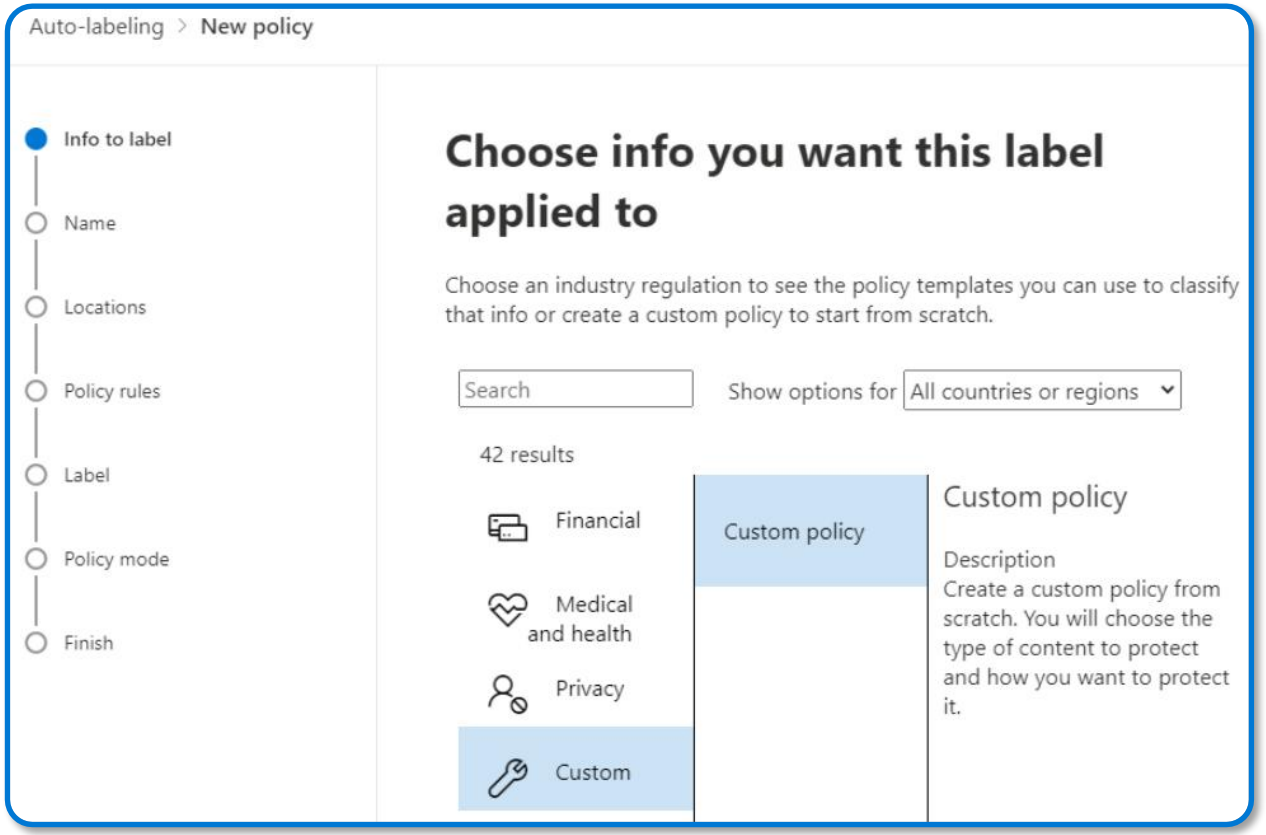
Auto-labeling ติด label ได้สม่ำเสมอทั่วทั้ง Microsoft 365 โดยไม่ต้องพึ่งให้ user เลือก label เอง

วิธีการ labeling:

- Client-side: ติด label ระหว่างแก้ไขใน Office app
- Service-side: ติด label ให้เนื้อหาที่จัดเก็บอยู่ใน SharePoint, OneDrive และ Exchange

การตั้งค่า policy:

- เลือก sensitive info type หรือ custom condition เป็นตัว trigger label
- ติด label ให้ไฟล์ อีเมล และเนื้อหาบน cloud
- ใช้ simulation mode ตรวจสอบ policy ก่อนบังคับใช้จริง

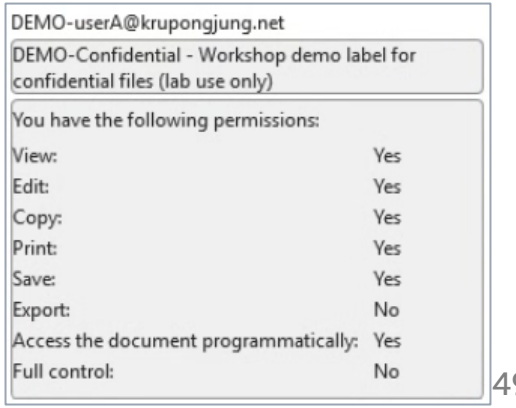


Permission แบบไหนที่ทำให้ Copilot ใช้เนื้อหาที่ encrypt ได้?

Copilot จะสรุปเนื้อหาที่ encrypt ได้เฉพาะกับ user ที่มีทั้ง VIEW และ EXTRACT (Copy) ถ้ามีแค่ VIEW จะได้แค่ link แต่ไม่ได้เนื้อหา

Permission level (ชื่อใน Purview portal)	มี EXTRACT หรือไม่?	Copilot ทำอะไรได้สำหรับ user คนนั้น
Viewer	ไม่มี	ได้เฉพาะ link ไปยัง item ไม่มีสรุป
Restricted Editor (เดิมชื่อ Reviewer)	ไม่มี	ได้เฉพาะ link ไปยัง item ไม่มีสรุป
Editor (เดิมชื่อ Co-Author)	มี	สรุปและอ้างอิงเนื้อหาได้
Owner (เดิมชื่อ Co-Owner)	มี	สรุปและอ้างอิงเนื้อหาได้
Custom permission ที่เลือก Copy (EXTRACT)	มี	สรุปและอ้างอิงเนื้อหาได้

- คนที่ใส่ encryption (Rights Management owner) มีสิทธิ์เต็มเสมอ
- วิธีตรวจสิทธิ์ของตัวเอง: เปิดไฟล์ใน Office desktop app แล้วไปที่ File > Info > Protect Document > View Permissions จะเห็นหน้าต่าง My Permission โดย Copy คือ EXTRACT



Activity explorer ไม่ใช่ real-time

Activity explorer อ่านข้อมูลจาก Microsoft 365 unified audit log ดังนั้น event จะแสดงตามรอบของ audit log ไม่ใช่ทันทีที่เกิดขึ้น



Action ของ user หรือ device

ติด label, DLP match, AI prompt

Unified audit log

Record ถูกเก็บรวบรวมและประมวลผล

Activity explorer

มุมมองแบบ filter ของ labeling และ DLP event

60–90 นาที

Delay ปกติของ Exchange, SharePoint, OneDrive และ Teams ส่วน service อื่นอาจนานกว่านี้

30 วัน

ประวัติ activity ที่ Activity explorer แสดงได้

เฉพาะตอน online

Endpoint device ส่งข้อมูลเฉพาะตอน online ถ้า offline จะส่งย้อนหลังหลังจากเชื่อมต่อใหม่

Teaching tip: ให้ติด label ตั้งแต่ต้น Lab 3 แล้วกลับมาดู Activity explorer หลังพัก ถ้าเห็นหน้าว่างทันทีหลังเปลี่ยนแปลง มักแปลว่าข้อมูลยังมาไม่ถึง

Lab 3 walkthrough: practice (Sensitivity labels)

#	ทำใน lab	Key Topic
1	เปิด Sxx-Confidential (seed ใน Lab 0) > Encryption: Sxx-lab = Editor, DEMO-userB = Viewer	Encryption + permissions: Editor (มี EXTRACT) vs Viewer (VIEW อย่างเดียว)
2	เปิด Sxx-LabelPolicy	label = ป้าย · policy = ประกาศว่าป้ายไหนถึงใคร ต้อง publish ก่อน ผู้ใช้จึงเห็นในแอป · Published to = จำนวน account ที่ได้รับ replication สูงสุด 24 ชม. (ปกติ ~2 ชม.) · Sync status = policy กระจายถึงระบบแล้วหรือยัง · Priority เลขมากชนะ
3	ติด label ใน CustomerList.docx ของ Sxx-Site ผ่าน Word for the web แล้วถาม Copilot: สรุปไฟล์นี้ใน 3 บรรทัด	Manual label · ผู้ติด label เป็น Rights Management owner (มี EXTRACT เสมอ) จึงเปิด แก้ และให้ Copilot สรุปได้
4	เปิดผล simulation ของ DEMO-AutoLabel (ถ้าทำงานเสริม 0.3 ดูสถานะ Sxx-AutoLabel ด้วย) · ห้ามกด Turn on (อยู่ติดปุ่ม View details)	Auto-apply (E5): client-side vs service-side · simulation ~12 ชม. ตาม Learn (ซ้อม 52 วินาที)
5	**DEMO** · ถาม Copilot กับ DEMO-Encrypted.docx ด้วย DEMO-userA (Editor) เทียบ DEMO-userB (Viewer) · ผู้เข้าอบรมจดผล	VIEW + EXTRACT กับ Copilot behavior · ผู้เข้าอบรมเป็นเจ้าของไฟล์ตัวเองจึงเปลี่ยนเป็น Viewer ไม่ได้ ดูจาก demo
6	Activity explorer > Activity = Label applied	Activity Explorer ไม่ใช่ real-time (60–90 นาที)

MODULE 4

Microsoft 365 E5 Compliance & Endpoint DLP



เวลา 14:00–14:55

Lab 4 · Endpoint DLP (Audit) จาก Lab 0, DLP alert ใน Defender XDR

Endpoint DLP **Service domains** **Browser-aware** **DLP alert**

ภาพรวม Data loss prevention

องค์กรใช้ DLP เพื่อป้องกันการแชร์โดยไม่ตั้งใจ หรือการใช้ข้อมูลสำคัญในทางที่ผิด ทั่วทั้ง Microsoft 365

DLP ปกป้องข้อมูลสำคัญอย่างไร:

- ตรวจจับและจำกัดข้อมูลสำคัญ ก่อนที่ข้อมูลจะออกนอกตำแหน่งที่อนุญาต
- ใช้ control แบบเดียวกัน ทั้ง Exchange, SharePoint, OneDrive และ Teams
- แนะนำ user ด้วย policy tip และ notification
- รองรับการบังคับใช้แบบ dynamic ด้วย Adaptive Protection

DLP policy ทำงานอย่างไร:



ระบุข้อมูลสำคัญ ในอีเมล ไฟล์ และ cloud storage

ติดตามว่า user ใช้งาน ข้อมูลสำคัญอย่างไร

Apply policy เพื่อ block, จำกัด หรือเตือน user ก่อนข้อมูลจะหลุดออกไป

Insider Risk Management: ดูความเสี่ยงจากพฤติกรรมของคน

ตรวจจับ สืบสวน และจัดการพฤติกรรมเสี่ยงของคนในองค์กร ทั้งตั้งใจและไม่ตั้งใจ เช่น ดึงข้อมูลออกก่อนลาออก ทำข้อมูลรั่ว หรือใช้ AI แบบเสี่ยง

1 Policy จาก template

เลือก template เช่น Data theft by departing users, Data leaks หรือ Risky AI usage แล้วกำหนด indicator และผู้ใช้ใน scope

2 Alert และ triage

ระบบคิด risk score จากชนิด ความถี่ และประวัติกิจกรรม แล้วออก alert ระดับ High / Medium / Low ให้ analyst triage

3 Case และ action

สืบสวนด้วย User activity และ Content explorer แล้วส่ง notice ปิดเป็น benign หรือ escalate ไป eDiscovery

Privacy by design: ชื่อผู้ใช้ถูก pseudonymize เป็นค่าเริ่มต้น และแยกสิทธิ์ตาม role group (Admins ตั้ง policy · Analysts ดู alert และ case · Investigators ดูเนื้อหาไฟล์ · Auditors ดู audit log) ระดับความเสี่ยงส่งต่อให้ DLP ผ่าน Adaptive Protection · มีใน Microsoft 365 E5

ตัวอย่างเหตุการณ์ที่ Insider Risk Management ตรวจเจอ

ตัวอย่างสมมติ 3 เหตุการณ์ ทุกเรื่องเริ่มจากพฤติกรรมของคน และ IRM ดูทั้งลำดับกิจกรรมกับบริบท ไม่ได้ดูไฟล์ทีละครั้งแบบ DLP

1 ลาออกแล้วขนข้อมูลออก

sales คนหนึ่งยื่นลาออก สัปดาห์ต่อมาดาวน์โหลดไฟล์ลูกค้า 300 ไฟล์ บีบเป็น zip เปลี่ยนชื่อ แล้ว upload ขึ้น cloud ส่วนตัว

Template: Data theft by departing users

2 ข้อมูลรั่วโดยไม่ตั้งใจ

พนักงานบัญชีส่งไฟล์ที่มีเลขบัตรเครดิตเข้า Gmail ตัวเองเพื่อทำงานต่อที่บ้าน DLP alert ระดับ High ทำให้ IRM เริ่มเฝ้าดู analyst ส่ง notice เตือนแล้วปิด case

Template: Data leaks

3 ใช้ AI แบบเสี่ยง

พนักงานวางสัญญาลูกค้าทั้งฉบับลงใน prompt ของ Copilot และเข้าเว็บ AI ภายนอกบ่อยผิดปกติ risk score สูงขึ้น DLP ของคนนี้เข้มขึ้นผ่าน Adaptive Protection

Template: Risky AI usage

ทำไม DLP อย่างเดียวไม่พอ: ในตัวอย่างที่ 1 แต่ละขั้นแยกกันดูเป็นงานปกติ และไฟล์อาจไม่ match DLP rule เลย IRM จับได้เพราะเห็นลำดับกิจกรรมของไฟล์ชุดเดียวกัน (เก็บรวบรวม ปกปิด ส่งออก) และรู้บริบทว่าคนนี้กำลังจะลาออก

Browser-aware enforcement

เมื่อไฟล์ match กับ DLP policy จะมีเฉพาะ browser ที่รองรับ DLP เท่านั้นที่เปิดและ upload ไฟล์นั้นได้



Unallowed browser

User เปิดไฟล์ที่ถูกปกป้องด้วย browser ที่อยู่ใน list unallowed

Access ถูก block

Endpoint DLP ไม่ให้ browser นั้นเปิดไฟล์

Toast แจ้ง user

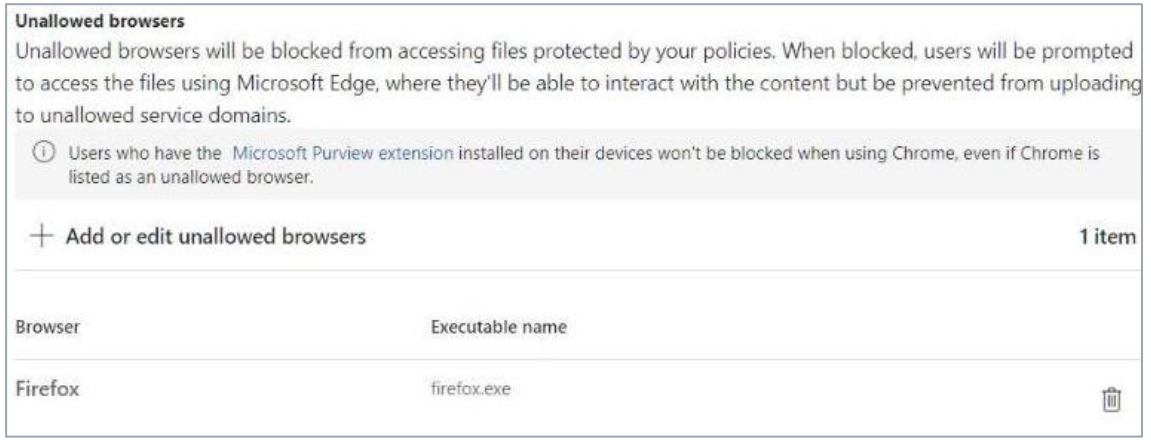
Notification แนะนำให้ user เปิดไฟล์ด้วย Microsoft Edge

Edge บังคับใช้ DLP

การ upload ถูก audit, block with override หรือ block

Browser (Windows)	การรองรับ DLP
Microsoft Edge	มีในตัว
Google Chrome	Microsoft Purview extension
Mozilla Firefox	Microsoft Purview extension

การ block unallowed browser มีผลเมื่อตั้ง upload restriction เป็น Block หรือ Block with override เท่านั้น ไม่ใช่ Audit only



เริ่มจาก audit แล้วค่อยเพิ่มระดับการบังคับใช้

เลือก action ให้แต่ละ device activity ใต้ “Audit or restrict activities on devices” และค่อยเพิ่มระดับหลังจากทบทวนผลแล้วเท่านั้น

Audit only

Log activity ไว้ โดยไม่ block user
Lab 4 เริ่มจากตรงนี้

Block with override

User ได้รับคำเตือนแต่ยังทำต่อได้ โดยอาจต้องระบุ business justification

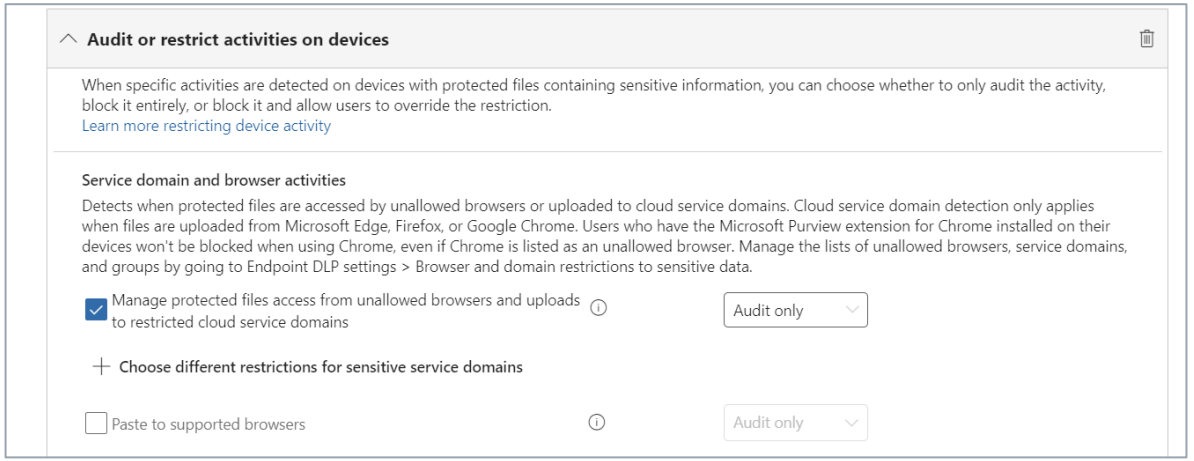
Block

Activity ถูกหยุดบน device

Policy mode

รันใน simulation ก่อน (จะแสดง policy tip หรือไม่ก็ได้) จากนั้นจึงเปิดใช้ policy

ใน Activity explorer ให้ filter Policy mode เพื่อดูค่า TestWithNotifyUser, TestWithoutNotifyUser หรือ Enforce



ก่อนสืบสวน: DLP alert tuning rule

ตั้งแต่ต้นเดือนตุลาคม 2026 Defender XDR มี built-in alert tuning rule ที่เปลี่ยน DLP signal ให้เป็น behavior ทำให้ไม่ขึ้นใน Incidents queue ตาม default

1 DLP policy match

Endpoint DLP rule ตรวจพบไฟล์สำคัญที่กำลังถูก upload ไปยัง restricted service domain

2 Built-in alert tuning rule

Signal ถูกบันทึกเป็น behavior ไม่ใช่ alert โดยเก็บใน table BehaviorInfo และ BehaviorEntities

3 Incidents queue

DLP incident จะขึ้นก็ต่อเมื่อปิด rule นี้แล้ว จากนั้น alert จะถูกรวมเป็น incident ตามปกติ

Lab 4 prerequisite (ตั้งค่าก่อนคลาส): ใน Microsoft Defender portal ไปที่ Settings > Microsoft Defender XDR > Alert tuning แล้วปิด built-in DLP rule ส่วน signal ที่ถูก tune ไปแล้วยังค้นหาได้ใน Advanced hunting

Lab 4 walkthrough: practice (Endpoint DLP)

#	ทำใน lab	Key Topic
1	สร้าง Sxx-EDLP: Devices (Sxx-lab) · SIT Credit Card Number · Manage protected files access from unallowed browsers and uploads to restricted cloud service domains = Audit only · alert · Mode = Off (ไม่ Turn on)	Endpoint DLP · audit-only mode · DLP alert (single-event) · ไม่มี device ใน scope จึงไม่เกิด event · เปิดจริงที่ DEMO-EDLP
2	Purview Settings > Solution settings > Data Loss Prevention > Endpoint DLP settings > Service domains และ Unallowed browsers (ดูอย่างเดียว)	Restricted service domain · browser-aware enforcement
3	**DEMO** · DEMO-PC: ตรวจ onboard + Purview extension บน Chrome	Edge native / Chrome ต้องมี extension (Windows)
4	**DEMO** · DEMO-PC: upload sample file ไป restricted domain แล้วเปิดด้วย unallowed browser · Audit only → Block with override	Audit only → Block with override (เส้นทางสู่ enforcement)
5	Activity explorer: filter DLP rule matched (event ของ DEMO-PC)	Audit event latency 60–90 นาที
6	Defender > Alerts > Service source = Microsoft Data Loss Prevention (alert ของ DEMO-PC ดูอย่างเดียว)	DLP alert tuning rule (ผู้สอนปิดไว้) · investigate: Alert story, Sensitive info types, Source

สร้าง Sxx-EDLP rule: ค่า default ที่ต้องแก้ก่อนกด Save

แก้ 3 จุดในหน้า Create rule

- File activities for all apps: เปลี่ยนเป็น Don't restrict file activity
- เอาติ๊ก Access by restricted apps ออก
- Severity: เลือก Low เอง (ช่องว่าง Select an option)

TL;DR ทำไมต้องแก้

- default ติ๊ก action เพิ่มให้หลายตัว แต่ทุกตัวเป็น Audit only จึงไม่อันตราย
- แต่เราสอน action เดียว: unallowed browsers + restricted cloud domains
- ถ้าปล่อยไว้ ผลปนกัน แยกไม่ออกว่าอะไรคือจุดสอน

- Policy mode = Leave the policy turned off · ห้ามเลือก Turn the policy on immediately
- หลัง Submit รายการ Policies ต้องขึ้น Sxx-EDLP = Off · Policy sync status อาจเป็น Sync in progress ซึ่งปกติ
- Protect sensitive data in Recall snapshots ไม่ได้ติ๊กไว้ตั้งแต่ต้น ไม่ต้องแก้ (ใช้กับ Copilot+ PC ที่เปิด Recall เท่านั้น)

MODULE 5

Copilot Governance, Agent Builder & RCD



เวลา 15:10–16:00

Lab 5 · สร้าง agent · Agent inventory · RCD

Copilot Control System **DSPM** **Agent Builder** **RCD**

คำเตือน – ขั้นตอนใน lab อาจไม่ตรงกับ UI

Microsoft cloud tool เปลี่ยนแปลงอยู่เสมอ จึงอาจเจอ user interface (UI) ของ Microsoft 365 ที่เปลี่ยนไปหลังจัดทำเอกสารหลักสูตร และไม่ตรงกับขั้นตอนใน lab

- Microsoft World-Wide Learning (WWL) พยายามอัปเดตขั้นตอน lab ให้ตรงกับ UI ล่าสุดของ Microsoft 365 เสมอ
- แต่อาจมีการเปลี่ยนแปลงที่เกิดขึ้นก่อน WWL จะทราบ
- ถ้าเจอแบบนี้ ให้ปรับตาม UI ที่เปลี่ยนไปแล้วทำ lab ต่อตามความเหมาะสม



Copilot Control System: 3 เสาหลัก

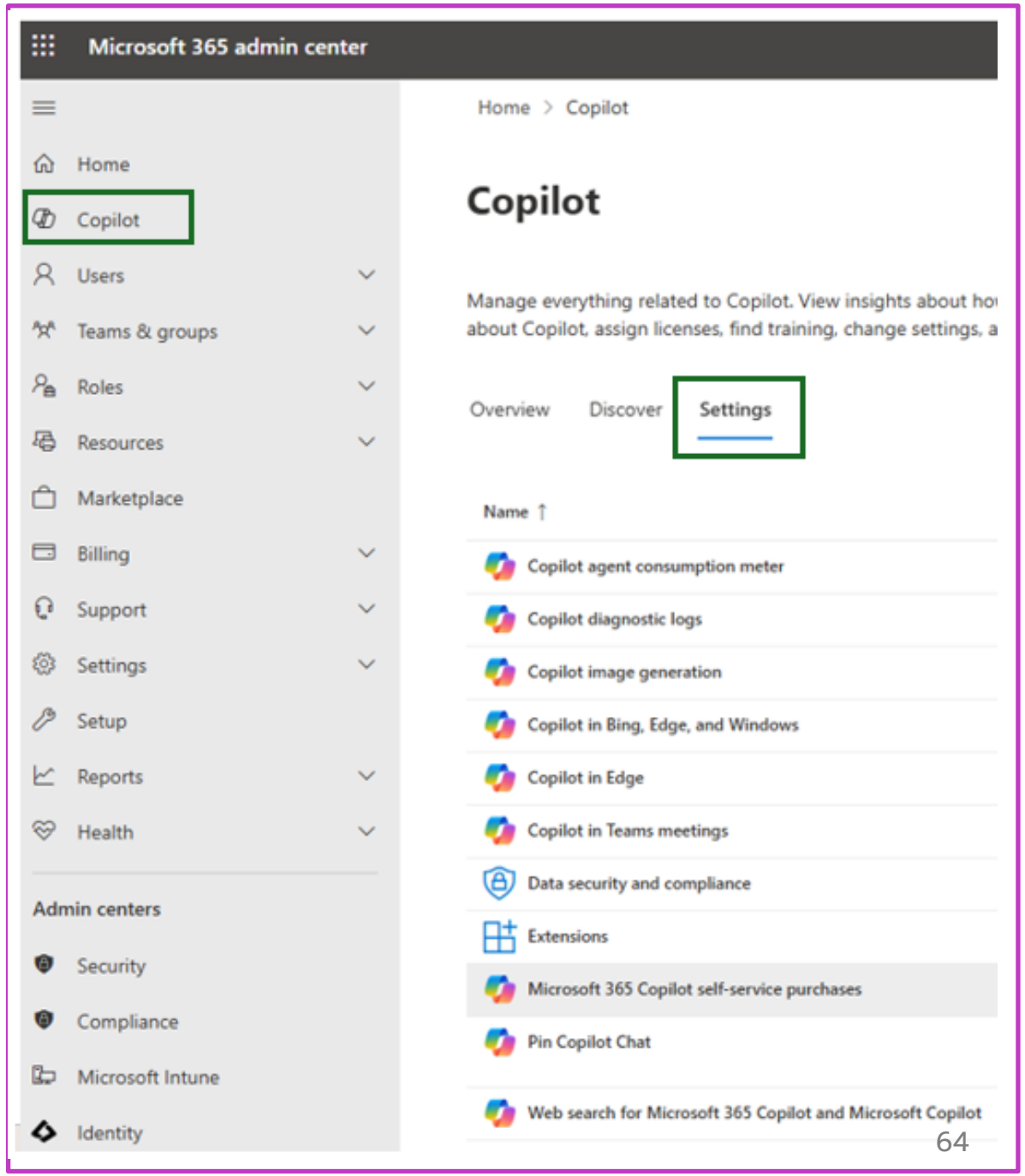


จัดการ setting ของ Microsoft 365 Copilot

จัดการวิธีที่ user ในองค์กรใช้ Microsoft 365 Copilot ได้ที่ tab **Settings** ในหน้า **Copilot** ของ Microsoft 365 admin center

ตัวอย่าง feature สำคัญใน tab Settings:







Monitor การใช้งานและ adoption ของ Microsoft 365 Copilot

ข้อมูล usage และ adoption ช่วยให้ตัดสินใจเรื่อง license และ feature จากหลักฐาน ไม่ใช่การคาดเดา

- การติดตาม adoption เริ่มจาก 2 ตัวเลขพื้นฐาน:
  - ใคร enabled (มี Copilot license)
  - ใคร active (ใช้ Copilot ในช่วงที่รายงาน)
- เมื่อได้ตัวเลขแล้ว ให้ดูต่อว่า:
  - Who: activity ล่าสุดของแต่ละ user
  - Where: แยกตาม app เช่น Outlook, Teams, Word/Excel/PowerPoint
  - When: รูปแบบตามเวลา ใช้ครั้งเดียวหรือใช้ต่อเนื่อง



Enabled vs. Active

Who · Where · When

ทำความเข้าใจ DSPM

DSPM เป็นศูนย์กลางในการดูการใช้งาน AI ระบุความเสี่ยง และใช้การปกป้องที่เหมาะสมกับ AI tool ทั้งของ Microsoft และ third-party



แสดงการใช้งาน AI tool ทั่วทั้งองค์กร และดูว่าเนื้อหาสำคัญไหลไปที่ใด



ชี้ความเสี่ยงที่ข้อมูลจะหลุด เพื่อจัดการ prompt, output หรือเงื่อนไขการเข้าถึงที่ไม่ปลอดภัย



เชื่อมไปยังโซลูชันของ Microsoft Purview เมื่อต้องตั้งค่า policy หรือ control



มี report, assessment และ insight ของ app และ agent activity เพื่อประเมินพฤติกรรมของ AI ได้ต่อเนื่อง

ดู prompt และ response ของ Copilot (E5)

Prompt และ response ถูกเก็บไว้ใน AI interaction event การจะดูข้อความได้ต้องมี license ที่ถูกต้อง เปิด auditing และมี role เพิ่มเติม

License

Microsoft 365 E5 เพิ่มความสามารถ "view prompt & response" ส่วน E3 ดูได้แค่ข้อมูล app และ activity

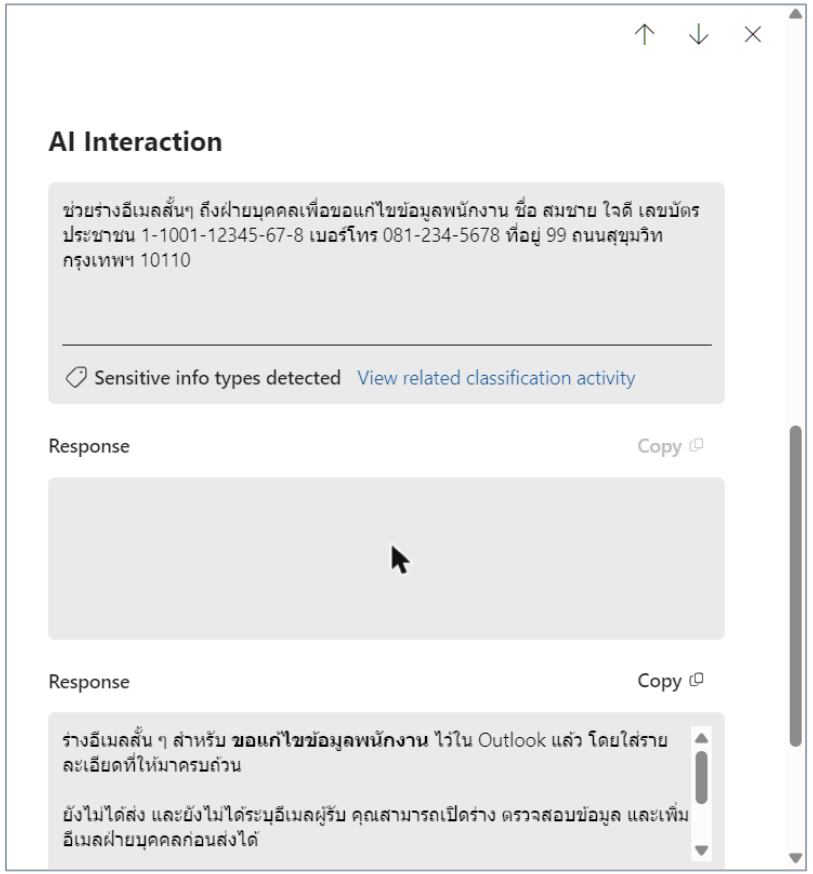
Auditing

ต้องเปิด Audit เพื่อให้ Copilot interaction ถูกบันทึก

Role

Compliance Administrator อย่างเดียวไม่พอ ต้องเพิ่ม Content Explorer Content Viewer หรือ Data Security AI Content Viewer

Path: DSPM > Discover > Activity explorer > AI activities > เลือก AI interaction event



Restricted Content Discovery (RCD)

Control ระดับ site แบบชั่วคราว ที่กัน SharePoint site ออกจาก organization-wide search และ Copilot ระหว่างที่ทบทวน permission

สิ่งที่ RCD ทำ

- ซ่อนเนื้อหาของ site จาก organization-wide search (SharePoint home, Office.com, Bing) และ Copilot discovery
- เอา Copilot entry point ออกจาก site เช่น Copilot button และ Create pages with AI
- แสดง tag Restricted บน site
- เปิดแล้ว ค้นได้เฉพาะในช่องค้นหาของ site เอง ไม่โผล่ใน Copilot และ AI agents

สิ่งที่ RCD ไม่ได้ทำ

- ไม่เปลี่ยน permission user ยังเปิดเนื้อหาที่ตัวเองมีสิทธิ์อยู่แล้วได้
- ไม่เอาเนื้อหาออกจาก index eDiscovery และ auto-labeling ยังทำงานตามปกติ
- ไม่มีผลกับ OneDrive หรือเนื้อหาที่ใช้งานอยู่แล้ว เช่น การสรุปเอกสารที่เปิดอยู่

Requirement: tenant มี user อย่างน้อย 1 คนที่ได้ license Microsoft 365 Copilot (จึงได้ SharePoint Advanced Management) ควรใช้ RCD อย่างเลือกสรร เพราะถ้า restrict หลาย site เกินไป คุณภาพของ search และคำตอบจาก Copilot จะลดลง

Lab 5 walkthrough: practice (Agent และ RCD)

#	ทำใน lab	Key Topic
A	สร้าง Sxx-Agent: Copilot app > Create agent > Configure: Description, Instructions, Starter prompts ตาม spec ใน worksheet · ปิด Knowledge ทั้ง 4 ตัว > Preview อย่างน้อย 2 prompt (ไม่เกิน 15 นาที) > Create	Declarative agent ด้วย Agent Builder (no-code) · agent ตอบจากข้อมูลที่ผู้ใช้มีสิทธิ์เข้าถึงเท่านั้น
B1	Microsoft 365 admin center > Agents > All agents: หา DEMO-Agent (ดูอย่างเดียว) และลองหา Sxx-Agent ของเรา	Agent inventory · ปุ่ม Total agents / Agents without owners · filter Status / Platform · ตอนซ้อม agent จาก Agent Builder ขึ้นแม้ Not shared
B2	**DEMO** · ผู้สอน Block / Unblock DEMO-Agent-2 แล้วดู Agent settings	Agent Builder governance · management controls (Sharing, User access)
C1	ดู tag Restricted บน Sxx-Site (ข้อเสริม: ถาม Copilot เรื่องประกาศ General Affairs และค้นใน Search จดผลที่เห็น) ผลอ้างอิงคือของ DEMO-userA	RCD ไม่เปลี่ยน permission · ผลถูกได้สองแบบ: Copilot ตอบไม่ได้แล้ว หรือยังตอบได้ชั่วคราวระหว่างรอ propagation (ตอนซ้อมเปลี่ยนภายในวันเดียว)
C2	Purview > Audit: ค้นหา RCD enable event	Purview Audit · audit event ใช้ 60–90 นาที
C3	**DEMO** · ผู้สอนถาม Copilot ด้วย DEMO-userA: เทียบ DEMO-Site ที่เปิด RCD กับ site ที่ไม่เปิด	ผลของ RCD ที่เห็นใน Copilot · propagation ขึ้นกับขนาด site

MODULE 6

Wrap-up + Q&A



เวลา 16:00–16:30

Verification Checkpoint, Q&A และทบทวน checklist

Verification Checkpoint **Rollout checklist** **Role separation** **Operational handoff**

Verification Checkpoint (16:00–16:15): ตรวจผลจริง

ตรวจอะไร	ที่ไหน	สร้างใน
ผล Report-only ของ Sxx-CA-SigninRisk	Entra > Sign-in logs > tab Report-only	Lab 1
Install status ของ DEMO-App v1/v2 บน DEMO-PC (ผู้สอนแสดง)	Intune > Apps > DEMO-App v1 > Device install status	Lab 2
Label event ของไฟล์ตัวเอง	Purview > Activity explorer	Lab 3
ผลถาม Copilot กับ CustomerList.docx ที่เราติด label	Copilot ใน Word for the web	Lab 3
สถานะ Sxx-AutoLabel (เฉพาะผู้ทำงานเสริม 0.3)	Purview > Auto-labeling policies	Lab 0 (เสริม)
DLP event และ DLP alert จาก DEMO-PC	Activity explorer · Defender XDR > Alerts	Lab 4
DEMO-Agent ใน inventory (ดูอย่างเดียว) และ Sxx-Agent ของเรา (ตอนซ้อมขึ้นทันทีแม้ยังไม่ share ถ้าไม่ขึ้นให้จดว่าผ่านไปกี่นาที)	Microsoft 365 admin center > Agents > All agents	Lab 5
RCD audit event	Purview > Audit	Lab 0 / Lab 5
ผลถาม Copilot หา PublicAnnouncement.docx หลังเปิด RCD (ข้อเสริม ใช้ผล DEMO-userA เป็นตัวอ้างอิง)	Microsoft 365 Copilot	Lab 0 / Lab 5

สรุปประเด็นสำคัญ: Zero Trust 6 phase กับสิ่งที่ทำวันนี้

Phase	Module	สิ่งที่ทำใน workshop
ประเมิน security posture ปัจจุบัน	M0	เทียบ plan BP / E3 / E5 และ map requirement กับ capability
เปิดใช้ identity protection	M1	Sign-in risk CA แบบ Report-only, Entra ID Protection
บังคับใช้ endpoint compliance	M2	Compliance policy (Firewall, Antivirus, Defender), Win32 app
จัดประเภทและปกป้องข้อมูล	M3 · M4 · M5	Sensitivity label + encryption, Endpoint DLP, RCD
Monitor และตอบสนองต่อ threat	M1 · M4	Incident/alert triage, DLP alert ใน Defender XDR
ให้ความรู้ผู้ใช้	M5	Agent governance, sharing policy และ Copilot adoption

จาก Report-only สู่ enforcement: เส้นทางเดียวกันทุก module

Module	วันนี้เริ่มแบบ	บังคับใช้เมื่อ	Checklist อยู่ที่
M1	CA policy เป็น Report-only	ผล Report-only ไม่กระทบ user สำคัญ	ไฟล์เต็ม หน้า 195
M2	Compliance policy ดูผลอย่างเดียว	device ส่วนใหญ่ compliant แล้วจึงใช้ CA	ไฟล์เต็ม หน้า 197
M3	Auto-labeling แบบ simulation	ตรวจผล simulation แล้วจึงเปิดใช้	ไฟล์เต็ม หน้า 196
M4	Endpoint DLP เป็น Audit only	Tune false positive แล้วเปลี่ยนเป็น Block with override	ไฟล์เต็ม หน้า 196
M5	Agent sharing เฉพาะ pilot group, RCD บาง site	Review oversharing และ agent inventory แล้ว	ไฟล์เต็ม หน้า 198

Role separation: ใครดูแลอะไร

งาน	Role (least privilege)	Portal
Identity และ CA	Conditional Access Administrator	Microsoft Entra admin center
Incident และ alert	Security Administrator / Security Operator	Microsoft Defender portal
DLP และ label	Compliance Administrator	Microsoft Purview portal
App และ compliance	Intune Administrator · Application Manager	Microsoft Intune admin center
RCD และ SAM	SharePoint Administrator	SharePoint admin center
Copilot และ agent	AI Administrator	Microsoft 365 admin center

Global Administrator เก็บไว้สำหรับ break-glass · วันนี้ใช้ Sxx-lab บัญชีเดียวเพื่อความง่าย ใน production แยก admin account ออกจาก account ใช้งานประจำวัน

Operational handoff: ใครดูอะไร ที่ไหน

ส่งต่องาน monitor ด้าน identity และ Defender ให้ทีม operation หลังจบ pilot

งาน	Role ที่รับ	ดูที่ไหน	ความถี่ (แนะนำ)
Triage incident และ alert	Security Operator	Defender portal > Incidents & alerts	ทุกวัน
ดู risky users และ risky sign-ins	Security Operator	Entra admin center > ID Protection	ทุกวัน
ทบทวนผล Report-only ก่อน enforce	Conditional Access Administrator	Sign-in logs > Report-only	ทุกสัปดาห์ช่วง pilot
ทบทวน DLP alert	Information Protection Analyst	Defender portal (filter DLP)	ทุกวัน
Device compliance (Firewall, Antivirus, Defender)	Intune Administrator	Intune > Devices > Compliance	ทุกสัปดาห์
ดูแล Alert service settings, Alert tuning, Email notifications	Security Administrator	Defender portal > Settings	เมื่อมีการเปลี่ยนแปลง

ความถี่เป็นค่าเริ่มต้นที่แนะนำ ปรับตามขนาดทีมและ SLA ขององค์กร

Q&A และขั้นถัดไป

Q&A

ถามได้ทุก module
จดเรื่องนอก scope ไว้คุยต่อ

ประเมิน tenant จริง

ใช้ checklist ของ M1–M5
เลือก pilot group
กำหนดเกณฑ์ก่อน enforce

อ่านต่อ

Microsoft Learn: Copilot setup
Agents admin guide
Zero Trust deployment

ขอบคุณที่ร่วม workshop